

Checklist

Vulnerability Management

1. Establish the Program

- ☐ Define a formal vulnerability management process.
- ☐ Document policies, procedures, roles, and responsibilities.
- ☐ Identify who owns vulnerability discovery, remediation, tracking, and reporting.
- ☐ Ensure the program covers detection through remediation, not just vulnerability scanning.
- ☐ Schedule vulnerability assessments on an ongoing basis rather than relying on one-time scans.

2. Determine Scan Approach

- ☐ Decide where authenticated scans are appropriate.
- ☐ Decide where unauthenticated scans are appropriate.
- ☐ Use authenticated scans when accurate software, patch, and configuration information is required.
- ☐ Use unauthenticated scans to understand what an external or credential-less attacker may observe.
- ☐ Do not rely solely on service banners or reported software versions.
- ☐ Validate questionable scan results to identify false positives and false negatives.
- ☐ Consider using both authenticated and unauthenticated scans for better coverage.

3. Secure Authenticated Scanning

- ☐ Create dedicated credentials for vulnerability scanning.
- ☐ Grant scanning accounts only the privileges required.
- ☐ Protect passwords, SSH keys, and other authentication material.
- ☐ Enable scanning credentials only during approved scan windows when possible.
- ☐ Disable scanning credentials when they are not required.
- ☐ Enable logging for scanner account activity.

- ☐ Review login times and source IP addresses for suspicious use.

4. Plan Safe Scanning

- ☐ Identify legacy or fragile systems before scanning.
- ☐ Test scanners against sensitive systems before broad deployment.
- ☐ Use lower-impact scans where appropriate.
- ☐ Schedule potentially disruptive scans during approved maintenance windows.
- ☐ Coordinate scanning with system owners.
- ☐ Have a rollback or recovery plan for systems that may be affected by scanning.

5. Select Vulnerability Assessment Tools

- ☐ Confirm the tool covers the technologies used in your environment.
- ☐ Identify gaps in operating system, application, network, or device coverage.
- ☐ Evaluate the level of automation provided.
- ☐ Determine the technical skill required to operate the tool effectively.
- ☐ Confirm the tool's scope matches your assessment goals.
- ☐ Check whether the tool detects missing patches and outdated software.
- ☐ Check whether it identifies configuration weaknesses.
- ☐ Check whether it supports web application or specialized scanning where required.
- ☐ Consider combining automated scanners with deeper manual or penetration-testing tools.

6. Consider Open-Source Options

- ☐ Evaluate Nmap-based scanning for network discovery and unauthenticated assessment.
- ☐ Consider tools such as Flan Scan where appropriate.
- ☐ Consider osquery for collecting endpoint software and configuration information.
- ☐ Compare discovered software versions against vulnerability databases such as CVE/NVD data.
- ☐ Confirm open-source tools provide sufficient coverage for your environment.

7. Initialize the Program

- ☐ Perform an initial vulnerability scan of the environment.
- ☐ Expect and plan for a potentially large initial backlog.
- ☐ Group findings by responsible operations or technology team.
- ☐ Separate findings by technology type where useful.
- ☐ Assign remediation responsibility to the appropriate teams.
- ☐ Group similar vulnerabilities into remediation batches.
- ☐ Identify vulnerabilities that occur frequently across many systems.
- ☐ Patch or correct common issues using standardized remediation procedures where possible.
- ☐ Group fixes into planned maintenance or engineering windows.
- ☐ Use coordinated changes to minimize repeated testing and reboot effort.
- ☐ Continue remediation cycles until the initial backlog becomes manageable.

8. Operate Vulnerability Management as Business as Usual

- ☐ Continuously discover vulnerabilities through scheduled scans.
- ☐ Monitor vendor security announcements.
- ☐ Monitor software and operating system security releases.
- ☐ Prioritize newly discovered vulnerabilities.
- ☐ Assign remediation work to responsible teams.
- ☐ Track remediation activity through completion.
- ☐ Rescan systems after remediation.
- ☐ Confirm resolved vulnerabilities no longer appear in scan results.
- ☐ Investigate vulnerabilities that remain after remediation attempts.

9. Prioritize Remediation

- ☐ Record the severity rating for each vulnerability.
- ☐ Use CVSS or an appropriate vendor severity rating where available.
- ☐ Avoid prioritizing solely by severity score.
- ☐ Add organizational and system context to the rating.

Consider Context

- ☐ Evaluate the sensitivity of data stored or processed by the affected system.
- ☐ Determine how many hosts are affected.
- ☐ Consider whether affected systems are business-critical.

- ☐ Determine whether the system is isolated, internal, partner-facing, or internet-facing.
- ☐ Increase priority for systems with greater attacker exposure.
- ☐ Consider exploitation complexity and required preconditions.
- ☐ Consider whether user interaction is required.
- ☐ Consider whether active exploitation is known or likely.
- ☐ Consider the potential business impact of successful exploitation.

10. Define Remediation Timelines

- ☐ Establish remediation SLAs based on severity and exposure.
- ☐ Document target remediation times.
- ☐ Track SLA compliance as a KPI where appropriate.
- ☐ Escalate overdue critical vulnerabilities.

Example Remediation Targets

- ☐ **Critical / Isolated LAN:** remediate within 7 days.
- ☐ **Critical / Internal LAN:** remediate within 2 days.
- ☐ **Critical / Partner-facing:** remediate within 1 day.
- ☐ **Critical / Internet-facing:** remediate within 1 day.
- ☐ **High / Isolated LAN:** remediate within 7 days.
- ☐ **High / Internal LAN:** remediate within 5 days.
- ☐ **High / Partner-facing:** remediate within 3 days.
- ☐ **High / Internet-facing:** remediate within 3 days.
- ☐ **Medium / Isolated LAN:** remediate within 14 days.
- ☐ **Medium / Internal LAN:** remediate within 7 days.
- ☐ **Medium / Partner-facing:** remediate within 5 days.
- ☐ **Medium / Internet-facing:** remediate within 5 days.
- ☐ **Low / Isolated LAN:** remediate within 21 days.
- ☐ **Low / Internal LAN:** remediate within 7 days.
- ☐ **Low / Partner-facing:** remediate within 14 days.
- ☐ **Low / Internet-facing:** remediate within 14 days.

11. Manage Risk Acceptance

- ☐ Use risk acceptance only when remediation is not practical within the required timeframe.

- ☐ Document why the vulnerability cannot currently be remediated.
- ☐ Identify any dependencies preventing remediation.
- ☐ Identify compensating controls where possible.
- ☐ Require approval from an appropriately senior risk owner.
- ☐ Record who accepted responsibility for the risk.
- ☐ Set an expiration date for every risk acceptance.
- ☐ Avoid permanent or indefinite risk acceptance.
- ☐ Review accepted risks periodically.
- ☐ Reassess the vulnerability before the acceptance expires.
- ☐ Remediate the vulnerability when circumstances allow.
- ☐ Require renewed approval if the risk must remain accepted after expiration.
- ☐ Remember that accepting a risk does **not** remove the vulnerability.

12. Measure Program Effectiveness

- ☐ Track the number of open vulnerabilities by severity.
- ☐ Track remediation times.
- ☐ Track vulnerabilities that exceed SLA targets.
- ☐ Track recurring vulnerabilities and configuration problems.
- ☐ Track accepted risks and their expiration dates.
- ☐ Review whether scanning coverage includes all relevant systems.
- ☐ Periodically reassess scanner effectiveness and coverage gaps.
- ☐ Use trends to improve patching, configuration management, and operational processes.